

QA Report: KYC Verification Service

Report ID: QA-PEG-002 | **Date:** 2026-04-09 | **Sprint:** Sprint 3 **Service:** Ubn-KYC-API | **Environment:** Development (dev-api.onecluster.co)

Executive Summary

The KYC Verification service provides identity verification capabilities for BVN, NIN, and CAC lookups. In sandbox mode, the service returns deterministic mock responses with masked PII to enable partner integration testing without accessing live identity databases. This report covers QA testing of all KYC endpoints on the development environment.

Scope

- POST /api/v1/kyc/bvn/verify — BVN identity verification
- POST /api/v1/kyc/nin/verify — NIN identity verification
- POST /api/v1/kyc/cac/lookup — CAC company registration lookup
- Sandbox mock response behavior (FULL_MATCH, masked PII)
- PII masking compliance across all responses
- HMAC-SHA256 signature validation on inbound requests
- Error handling and validation

Changes This Sprint (Mar 31 — Apr 9)

- 12 commits to Ubn-KYC-API
- CI/CD pipeline updates for automated deployment
- VPS deployment configuration
- Sandbox mock response refinements
- HMAC signature validation improvements
- Logging enhancements for audit trail

Test Results

BVN Verification

Test ID	Test Case	Expected	Actual	Status	Notes
QA-KYC-001	Verify BVN with valid payload	200 with verificationStatus:"FULL_MATCH"	200 with verificationStatus:"FULL_MATCH", bvn:"****"	PASS	PII correctly masked in sandbox responses
QA-KYC-002	Verify BVN with missing HMAC header	401 HMAC_REQUIRED	401 with error:"HMAC signature is required"	PASS	Security gate enforced
QA-KYC-003	Verify BVN with invalid HMAC	401 HMAC_INVALID	401 with error:"HMAC signature validation failed"	PASS	Tampered request rejected
QA-KYC-004	Verify BVN with empty body	422 Validation error	422 with field-level errors (bvn, firstName, lastName required)	PASS	Proper validation

QA-KYC-005	Verify BVN with invalid BVN format	422 INVALID_BVN_FORMAT	422 with error:"BVN must be 11 digits"	PASS	Format validation enforced
QA-KYC-006	Field name: verificationStatus vs matchResult	matchResult per OpenAPI spec	verificationStatus returned	FAIL	See ISSUE PEG-38 — field name does not match spec

NIN Verification

Test ID	Test Case	Expected	Actual	Status	Notes
QA-KYC-007	Verify NIN with valid payload	200 with verificationStatus:"FULL_MATCH"	200 with verificationStatus:"FULL_MATCH", nin:"****"	PASS	NIN masked in response
QA-KYC-008	Verify NIN with missing fields	422 Validation error	422 with field-level errors	PASS	Consistent validation pattern
QA-KYC-009	Verify NIN with invalid NIN format	422 INVALID_NIN_FORMAT	422 with error:"NIN must be 11 digits"	PASS	Format validation enforced
QA-KYC-010	NIN response PII masking	All PII fields masked	nin:""; dateOfBirth: ""; photo:null	PASS	Comprehensive PII scrubbing

CAC Lookup

Test ID	Test Case	Expected	Actual	Status	Notes
QA-KYC-011	CAC lookup with valid RC number	200 with company details	200 with companyName, companyStatus, registrationDate	PASS	Returns structured company data
QA-KYC-012	CAC lookup with invalid RC number	404 COMPANY_NOT_FOUND	404 with error:"Company not found"	PASS	Sandbox returns 404 for non-seeded RC numbers
QA-KYC-013	CAC lookup PII masking	Director PII masked	Directors array contains masked names and IDs	PASS	Director-level PII scrubbed

QA-KYC-014	CAC lookup with missing HMAC	401 HMAC_REQUIRED	401 with error:"HMAC signature is required"	PASS	Consistent security enforcement
------------	------------------------------	-------------------	---	------	---------------------------------

HMAC Signature Validation

Test ID	Test Case	Expected	Actual	Status	Notes
QA-KYC-015	Valid HMAC-SHA256 signature	Request accepted	Request processed successfully	PASS	HMAC computed over request body
QA-KYC-016	Expired timestamp in HMAC	401 HMAC_EXPIRED	401 with error:"Request timestamp expired"	PASS	5-minute window enforced
QA-KYC-017	Replay attack (duplicate nonce)	401 HMAC_REPLAY	Not tested — requires stateful nonce store	NOT RUN	Code review confirms nonce check exists

Issues Found

ID	Severity	Issue	Status
PEG-384	Medium	Response field name is verificationStatus but OpenAPI spec defines matchResult — inconsistency will break partner integrations if spec is published as-is	OPEN
PEG-390	Low	Sandbox mock responses do not include requestId field for correlation — partners cannot trace requests end-to-end	OPEN

PII Masking Compliance

Field	Expected Masking	Actual Masking	Status
bvn	Fully masked (***)	***	COMPLIANT
nin	Fully masked (***)	***	COMPLIANT
dateOfBirth	Fully masked (***)	***	COMPLIANT
phoneNumber	Fully masked (***)	***	COMPLIANT
photo	Null in sandbox	null	COMPLIANT
firstName	Returned (non-sensitive in context)	Returned	COMPLIANT
lastName	Returned (non-sensitive in context)	Returned	COMPLIANT

Recommendations

- Resolve PEG-384: Align response field name (verificationStatus vs matchResult) before partner onboarding begins — breaking change if deferred
- Add requestId to all sandbox responses for end-to-end traceability
- Implement integration tests for HMAC replay protection (nonce store)
- Consider adding rate limiting per partner API key to prevent abuse of KYC endpoints